

Ministère de l'Éducation Nationale

# **RAPID7 InsightVM** VS **CYBERWATCH Vulnerability Manager**

Analyse comparative fondée sur les documentations officielles des éditeurs

|                       |                                                            |
|-----------------------|------------------------------------------------------------|
| <b>Commanditaire</b>  | Ministère de l'Éducation Nationale — DNE                   |
| <b>Destinataires</b>  | DSI, RSSI, comité de sélection cybersécurité               |
| <b>Périmètre</b>      | Prérequis · Découverte · Scan · Remédiation · Priorisation |
| <b>Sources</b>        | docs.rapid7.com · docs.cyberwatch.com                      |
| <b>Classification</b> | <b>DIFFUSION RESTREINTE</b>                                |

## Table des matières

---

|                                                                                      |    |
|--------------------------------------------------------------------------------------|----|
| Table des matières .....                                                             | 1  |
| Cadrage de l'étude.....                                                              | 2  |
| Résultats consolidés .....                                                           | 3  |
| 1. Prérequis système : ce que chaque solution exige de votre infrastructure .....    | 4  |
| 1.1. Serveur central.....                                                            | 5  |
| 1.2. Agent et architecture distribuée .....                                          | 5  |
| 2. Découverte d'actifs : savoir ce que l'on protège .....                            | 6  |
| 2.1. Virtualisation et annuaires .....                                               | 7  |
| 2.2. Équipements réseau et conteneurs .....                                          | 7  |
| 2.3. Surface externe.....                                                            | 8  |
| 3. Modes de scan : comment chaque solution inspecte votre SI .....                   | 8  |
| 3.1. Modes de scan .....                                                             | 9  |
| 3.2. Gestion PAM.....                                                                | 9  |
| 3.3. Validation d'exploitabilité .....                                               | 10 |
| 4. Déploiement de correctifs : combler le fossé entre détection et remédiation ..... | 10 |
| 4.1. Rapid7 : assistance au patching via outil tiers.....                            | 11 |
| 4.2. Cyberwatch : module de déploiement natif et intégré .....                       | 11 |
| 4.3. Comparaison détaillée .....                                                     | 11 |
| 5. Priorisation : trier 12 000 vulnérabilités pour agir sur les bonnes .....         | 12 |
| 5.1. Rapid7 : écosystème propriétaire d'une richesse inégalée .....                  | 13 |
| 5.2. Cyberwatch : standards ouverts et transparence totale .....                     | 13 |
| 6. Grille de synthèse — 24 critères.....                                             | 14 |
| 7. Sources documentaires .....                                                       | 16 |
| 7.1. Rapid7 — 17 sources.....                                                        | 17 |
| 7.2. Cyberwatch — 21 sources .....                                                   | 17 |

---

## Cadrage de l'étude

---

Le présent document compare deux solutions de gestion des vulnérabilités pour le compte de la Direction du Numérique pour l'Éducation. L'analyse porte exclusivement sur les documentations techniques publiques des éditeurs, consultées en février 2026. Aucune donnée commerciale, aucun retour d'expérience terrain, aucun résultat de POC n'a été pris en compte.

**Contexte ministériel.** Le Ministère gère un parc hétérogène réparti sur 30+ académies et de nombreux CROUS. Serveurs sous Debian/Ubuntu en français, 8-16 Go RAM, WAPT généralisé, pare-feu Stormshield et Fortinet, hyperviseurs Hyper-V/Proxmox, réseaux pédagogiques air gap, obligations ANSSI/CNIL.

**Barème.** 24 critères notés sur 5 (120 points max). Ce score est un outil d'aide à la décision, pas un substitut à un POC.

---

## Résultats consolidés

|                                                                                                  |                                                                                                       |
|--------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| <b>RAPID7 InsightVM</b><br><b>48 / 120</b><br>Threat Intelligence, Metasploit RCS, Project Sonar | <b>CYBERWATCH</b><br><b>100 / 120</b><br>Remédiation native, air gap, conteneurs, souveraineté, ANSSI |
|--------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|

Rapid7 concentre ses forces sur la Threat Intelligence propriétaire (Metasploit, Sonar, AttackerKB, Lorelei) et la validation d'exploitabilité réelle. Sa faiblesse structurelle : aucun module de remédiation intégré, couverture limitée des équipements et standards français.

Cyberwatch offre une couverture fonctionnelle homogène sur l'ensemble du cycle : découverte, détection, priorisation et déploiement dans une console unique. Support natif des équipements souverains, WAPT bidirectionnel, air gap complet, standards ouverts auditables.

### Recommandation

Au regard de l'infrastructure existante, les critères dominés par Cyberwatch ont un impact opérationnel plus immédiat. Rapid7 reste pertinent si le Ministère dispose déjà d'une chaîne SCCM/BigFix. Un POC sur 2-3 académies est fortement recommandé.

## 1. Prérequis système : ce que chaque solution exige de votre infrastructure

Avant de parler de fonctionnalités, il faut s'assurer que la solution peut tourner sur le matériel existant. Dans les académies, les serveurs dépassent rarement 16 Go de RAM et fonctionnent sous Debian ou Ubuntu en français.

### 1.1. Serveur central

| Prérequis              | Rapid7 InsightVM                                                | Cyberwatch                                                  |
|------------------------|-----------------------------------------------------------------|-------------------------------------------------------------|
| Mémoire vive           | 16 Go minimum — allocation exacte exigée                        | 12 Go avec 2 vCPU. 25 % de moins.                           |
| Espace disque          | 100 Go min., 1 To recommandé. Scans auth. = ~10x plus d'espace. | 40 Go (images Docker + données).                            |
| Système d'exploitation | RHEL / Windows Server. OS anglais obligatoire.                  | Toute distrib. Linux + Docker. Aucune contrainte de langue. |
| Base de données        | PostgreSQL embarqué                                             | Conteneurisée, aucune BDD externe                           |
| Conteneurisation       | Console non supportée en conteneur                              | Docker Swarm (recomm.), K8s, Podman                         |
| Accès internet         | Cloud AWS obligatoire pour fonctions avancées                   | Air gap complet possible                                    |

**Pourquoi c'est important.** Un Debian 12 français avec 12 Go de RAM — configuration typique en académie — ne peut pas héberger Rapid7 en l'état. Il faudrait augmenter la RAM, réinstaller l'OS en anglais et garantir un accès permanent au cloud AWS. Cyberwatch s'installe sans modification.

### 1.2. Agent et architecture distribuée

| Composant                | Rapid7 InsightVM                                       | Cyberwatch                             |
|--------------------------|--------------------------------------------------------|----------------------------------------|
| Agent (OS)               | Win 64-bit, macOS, Linux 64-bit (fin 32-bit : 05/2025) | Win, Linux, macOS — MSI, DEB, RPM      |
| Localisation des données | Cloud Rapid7 (AWS, région US)                          | Serveur local strict (on-premise)      |
| Relais                   | Collector : max 600 agents/cœur CPU                    | Satellite : 2 vCPU, 8 Go, 20 Go disque |
| Multi-sites              | Multi Scan Engines + Azure Scan Engines                | Cluster Docker Swarm/K8s + satellites  |

**Souveraineté des données.** Avec Rapid7, les données de vulnérabilité (CVE, versions logicielles, configurations) transitent par un cloud américain. Avec Cyberwatch, rien ne sort du réseau local. Pour un ministère régalien soumis au RGPD, cette distinction est déterminante.

**Détail technique — Flux réseau et dépendances**

Rapid7 InsightVM requiert des connexions sortantes permanentes vers plusieurs endpoints AWS : data.insight.rapid7.com (télémétrie agent), us.storage.endpoint.ingress.rapid7.com (stockage scans), exposure-analytics.insight.rapid7.com (dashboards EPSS). Le Collector sert de relais pour les agents mais ne supprime pas la dépendance cloud — il la concentre. La bande passante consommée dépend du nombre d'actifs : Rapid7 documente environ 2 Ko/agent/jour en état stable, mais les scans complets génèrent des pics significatifs. Cyberwatch ne nécessite que deux domaines (dl.cyberwatch.com pour les mises à jour logicielles, securitydb.cyberwatch.com pour la base CVE). En mode air gap, ces deux flux sont remplacés par un import manuel via clé USB ou partage réseau isolé. L'architecture Docker Swarm de Cyberwatch permet un redémarrage automatique des services en cas de panne d'un nœud, sans intervention manuelle.

**Dimensionnement en conditions réelles.** Pour un parc de 5 000 actifs (scénario d'une académie de taille moyenne), Rapid7 recommande 32 Go de RAM pour la Security Console, 500 Go de disque SSD, et au moins 2 Scan Engines dédiés. Le Collector supporte 600 agents par cœur CPU, soit 4 800 agents pour un Collector 8-cœurs. Côté Cyberwatch, un serveur central de 16 Go avec 2-3 satellites répartis sur les sites distants couvre le même périmètre. Chaque satellite nécessite seulement 2 vCPU et 8 Go de RAM, ce qui le rend déployable sur un serveur virtualisé existant sans acquisition matérielle supplémentaire.

#### Verdict — Prérequis

##### **Rapid7 InsightVM**

Exige plus de ressources, un OS anglophone et un cloud permanent. Adapté aux infras modernes avec connectivité garantie.

##### **Cyberwatch**

S'installe sur l'existant sans modification. Air gap complet. Données souveraines. Satellites légers pour les sites distants.

## 2. Découverte d'actifs : savoir ce que l'on protège

On ne protège pas ce qu'on ne connaît pas. Le SI ministériel est hétérogène : hyperviseurs variés, équipements de sécurité français, annuaires multiples, cloud croissant, conteneurs. La profondeur des connecteurs natifs est un critère discriminant.

### 2.1. Virtualisation et annuaires

| Connecteur       | Rapid7 InsightVM       | Cyberwatch      |
|------------------|------------------------|-----------------|
| VMware vCenter   | ✓ Discovery native     | ✓ Natif         |
| ESXi standalone  | Via vCenter uniquement | ✓ Direct        |
| Hyper-V          | X Non documenté        | ✓ Natif         |
| Nutanix          | X Non documenté        | ✓ Natif         |
| Proxmox          | X Non documenté        | ✓ Natif         |
| Active Directory | ✓ Dynamic Discovery    | ✓ Natif         |
| Entra ID         | X Non documenté        | ✓ Natif         |
| DHCP Logs        | ✓ Dynamic Discovery    | X Non documenté |

**Concrètement :** Hyper-V, Proxmox et Nutanix sont omniprésents dans les académies. Sans connecteur natif, Rapid7 ne découvre pas les VM qui y tournent — il faut installer un agent sur chacune d'entre elles. Cyberwatch interroge directement l'hyperviseur via ses API natives (System Center VMM pour Hyper-V, API REST Proxmox, Prism API pour Nutanix). Cette approche permet de découvrir y compris les VM éteintes ou en cours de provisionnement, ce que l'agent ne peut pas faire puisqu'il nécessite un OS en cours d'exécution.

#### Détail technique — Protocoles de découverte

Rapid7 utilise un mécanisme appelé Dynamic Discovery qui s'appuie sur des connexions directes aux API VMware vCenter (port 443/HTTPS), aux serveurs LDAP/AD (ports 389/636), aux sources DHCP et aux agents McAfee ePO. Chaque connexion est configurée manuellement dans la console avec un intervalle de synchronisation. Cyberwatch propose un mécanisme similaire mais étend les connecteurs à WMI (port 5985/5986 pour Hyper-V), API REST Proxmox (port 8006), Prism Central (port 9440), SNMP v2c/v3 pour les équipements réseau, et des connecteurs dédiés pour Stormshield SNS (API REST SNS) et Fortinet (FortiOS API). La différence clé : Cyberwatch intègre nativement les protocoles utilisés par les équipements déployés dans le secteur public français, tandis que Rapid7 se concentre sur l'écosystème VMware/AD/AWS.

### 2.2. Équipements réseau et conteneurs

Cyberwatch dispose de connecteurs natifs pour Stormshield SNS et Fortinet (les deux constructeurs les plus déployés dans les académies). Le connecteur Stormshield utilise l'API REST SNS pour interroger directement le firmware, la configuration et les modules actifs du pare-feu. Le connecteur Fortinet utilise FortiOS REST API. Côté conteneurs, Cyberwatch couvre 11 registres et

orchestrateurs (Docker Registry, Amazon EKS/ECR, Azure AKS, Kubernetes natif, Red Hat OpenShift, Harbor, GitLab Container Registry, Docker Swarm, Rancher, CI/CD GitLab). L'intégration CI/CD permet de scanner les images avant leur déploiement en production — approche shift-left. Rapid7 ne scanne les conteneurs que via l'Insight Agent installé sur l'hôte Docker, ce qui signifie qu'il détecte les vulnérabilités du runtime mais pas celles embarquées dans les images elles-mêmes.

#### Détail technique — Scan conteneurs

Quand Cyberwatch scanne un registre Docker, il récupère le manifeste de chaque image (via l'API Docker Registry v2), extrait les couches (layers), analyse le SBOM (Software Bill of Materials) de chaque couche, et corrèle les paquets détectés avec sa base de 200 000+ CVE. Ce processus s'applique identiquement sur EKS, AKS, OpenShift ou Harbor. L'intégration CI/CD GitLab insère cette analyse dans le pipeline : si une CVE critique (CVSS  $\geq$  9.0) est détectée, le pipeline peut être bloqué avant le push en production. Rapid7 InsightVM, dans sa documentation propre (hors InsightCloudSec), ne propose pas ce type d'intégration.

### 2.3. Surface externe

**Project Sonar** est l'atout unique de Rapid7 : scan continu de tout l'internet public, intégré au scoring des actifs exposés. Aucun équivalent sur le marché. Cyberwatch compense par des méthodes ciblées (DNS, Certificate Transparency, WHOIS, reverse DNS), mieux adaptées à un périmètre institutionnel connu.

#### Verdict — Découverte

##### Rapid7 InsightVM

Project Sonar unique. Lacunaire sur Hyper-V, Proxmox, Stormshield, conteneurs.

##### Cyberwatch

Couverture native des hyperviseurs et équipements souverains. 11 registres conteneurs. Pas de surface internet globale.



### 3. Modes de scan : comment chaque solution inspecte votre SI

Le mode de scan (agent, credentials, air gap) dépend de la topologie réseau et de la politique de sécurité. La gestion des comptes à privilèges (PAM) détermine si les credentials de scan sont stockés de manière sécurisée.

#### 3.1. Modes de scan

| Mode                   | Rapid7 InsightVM                    | Cyberwatch                            |
|------------------------|-------------------------------------|---------------------------------------|
| Agent                  | Win/Linux/macOS 64-bit              | Win/Linux/macOS — MSI, DEB, RPM       |
| Sans agent             | SSH, WinRM, SNMP, SMB               | WinRM, SSH + gestionnaires de secrets |
| Air gap                | X MAJ signatures uniquement         | ✓ Scripts PS/Bash + USB + import SBOM |
| Conteneurs             | Agent sur l'hôte Docker             | ✓ Scan natif multi-registres          |
| Web / Cloud compliance | Produits séparés (AppSec, CloudSec) | ✓ Intégré dans la console unique      |

**Focus air gap.** Dans les réseaux pédagogiques isolés, Rapid7 se limite à la mise à jour des signatures. Cyberwatch propose un workflow complet : script local sur les machines cibles, export USB, import dans la console, corrélation CVE. Différence structurante pour un ministère avec des milliers de postes déconnectés.

#### Détail technique — Workflow air gap Cyberwatch

Le processus se décompose en 4 étapes documentées. (1) Génération des scripts : depuis la console Cyberwatch, l'administrateur exporte un script PowerShell (Windows) ou Bash (Linux) contenant les règles de collecte. (2) Exécution locale : le script est exécuté sur chaque machine cible via GPO, WAPT, ou manuellement. Il collecte l'inventaire logiciel (registre Windows, dpkg/rpm sous Linux), les configurations système et les éléments de sécurité. Le résultat est un fichier JSON/SBOM déposé sur un partage local ou une clé USB. (3) Transfert : les fichiers sont transférés physiquement vers le réseau où se trouve la console Cyberwatch. (4) Import et corrélation : Cyberwatch ingeste les SBOM et les corrèle avec sa base CVE locale (mise à jour périodiquement via le même processus physique). Les vulnérabilités détectées apparaissent dans les dashboards comme pour un scan en ligne. Côté Rapid7, le mode Offline Updates permet uniquement de mettre à jour la base de signatures CVE de la console — pas de réaliser un scan distant ni d'importer des inventaires.

### 3.2. Gestion PAM

| Coffre-fort      | Rapid7     | Cyberwatch       |
|------------------|------------|------------------|
| CyberArk         | ✓ Oui      | ✓ Oui            |
| HashiCorp Vault  | X Non doc. | ✓ Oui            |
| WALLIX Bastion   | X Non doc. | ✓ Oui            |
| Conjur           | X Non doc. | ✓ Oui            |
| Kerberos         | ✓ Oui      | X Non doc.       |
| NTLM Hash        | ✓ Oui      | X Non doc.       |
| AWS SSM / Intune | X Non doc. | ✓ Oui (les deux) |

**WALLIX Bastion** est le PAM le plus déployé dans les administrations françaises (qualifié ANSSI). Son support natif par Cyberwatch permet l'injection dynamique des credentials sans stockage dans la console du scanner. Techniquement, Cyberwatch interroge l'API WALLIX Access Manager pour obtenir un jeton temporaire (lease) avant chaque scan authentifié. Le credential n'est jamais écrit en base — il existe uniquement en mémoire pendant la durée du scan, puis est révoqué. Ce modèle est conforme aux recommandations ANSSI R14 (gestion des comptes d'administration) et R34 (cloisonnement des secrets). Côté Rapid7, l'absence de connecteur WALLIX impose soit de stocker les credentials directement dans InsightVM (risque de compromission en cas d'accès non autorisé à la console), soit de développer un pont spécifique via scripts.

### 3.3. Validation d'exploitabilité

**Metasploit Remote Check Service** (Rapid7) exécute un module d'exploitation non destructif pendant le scan pour confirmer l'exploitabilité réelle. Taux de faux positifs considérablement réduit. Cyberwatch référence les exploits publics mais ne les exécute pas. En contrepartie, Cyberwatch publie des chiffres vérifiables (80 000 produits, 200 000 fiches CVE, MAJ horaire) et intègre les sources françaises (CERT-FR).

#### Détail technique — Metasploit Remote Check Service

Le fonctionnement du RCS mérite un développement. Lorsque le Scan Engine Rapid7 détecte une CVE potentielle (par exemple CVE-2024-XXXXX sur un service Apache), il peut invoquer un module Metasploit « check » spécifique. Ce module tente une exploitation partielle (sans payload destructif) pour confirmer que la vulnérabilité est réellement présente et exploitable dans le contexte exact de la machine cible (version précise, configuration, protections actives). Le résultat est binaire : « vulnerable » ou « not vulnerable ». Cela transforme une suspicion basée sur un numéro de version en une certitude technique. La base Metasploit compte plus de 2 300 modules de vérification à la date de rédaction. Aucun autre éditeur du marché ne dispose d'un équivalent. Cyberwatch, de son côté, référence l'existence d'exploits publics (via CISA KEV et exploit-db) mais ne les exécute pas — la détection reste fondée sur la correspondance version/CVE.

**Verdict — Scan****Rapid7 InsightVM**

Metasploit RCS unique. Air gap limité. Fonctions web/cloud dans des produits séparés.

**Cyberwatch**

Console unifiée, air gap complet, PAM étendu (dont WALLIX). Pas de validation d'exploitabilité active.

## 4. Déploiement de correctifs : combler le fossé entre détection et remédiation

C'est le point de divergence le plus net. La question : une fois la vulnérabilité détectée, l'outil déploie-t-il le correctif, ou faut-il un autre produit ?

### 4.1. Rapid7 : assistance au patching via outil tiers

InsightVM propose de l'« Automation-Assisted Patching » : il déclenche un workflow dans SCCM ou BigFix. Ces deux outils doivent être déployés, configurés et licenciés indépendamment. InsightVM ne déploie aucun correctif par lui-même. Pour une académie sans SCCM ni BigFix, il n'y a aucune automatisation de la remédiation.

### 4.2. Cyberwatch : module de déploiement natif et intégré

**Windows KB** : déploiement natif + détection WSUS automatique + approbation auto. **Logiciels tiers** : via winget + désinstallation MSI. **Linux** : apt, yum, dnf natifs + Red Hat Satellite. **Planification** : fenêtres de maintenance, redémarrage auto, affectation par groupe.

**Intégration WAPT.** L'API bidirectionnelle Cyberwatch-WAPT boucle la chaîne : détection d'une vulnérabilité → identification du paquet WAPT de correction → déploiement automatique via l'infrastructure WAPT existante. Atout décisif quand WAPT est déjà le standard de déploiement.

#### Détail technique — Chaîne de remédiation Cyberwatch + WAPT

Le scénario type est le suivant. Cyberwatch détecte que Firefox 120 est vulnérable à CVE-2024-XXXXX sur 800 postes d'une académie. Le module de patch management identifie qu'un paquet WAPT « tis-firefox-esr » version 121 est disponible dans le dépôt WAPT local. Via l'API bidirectionnelle, Cyberwatch déclenche le déploiement du paquet sur les 800 postes concernés. WAPT gère le téléchargement, l'installation silencieuse et le reporting. Cyberwatch re-scanner ensuite les postes pour vérifier la remédiation. Tout ce cycle peut être automatisé sans intervention humaine. C'est un avantage considérable dans un contexte où les équipes SSI académiques sont souvent restreintes à 1-2 personnes pour des milliers de postes.

#### Détail technique — Déploiement Linux natif

Sur les serveurs Linux (Debian, Ubuntu, RHEL, CentOS, Rocky), Cyberwatch exécute directement les commandes du gestionnaire de paquets natif : apt-get upgrade [paquet] sur Debian/Ubuntu, yum update [paquet] ou dnf upgrade [paquet] sur Red Hat et dérivés. La politique de déploiement permet de définir des fenêtres de maintenance (par exemple : samedi 2h-6h) avec redémarrage automatique si le noyau a été mis à jour. Pour les parcs RHEL sous gestion Red Hat Satellite, Cyberwatch s'intègre comme consommateur de contenu Satellite, évitant la duplication des dépôts. Rapid7 ne propose aucune capacité équivalente sur Linux — la remédiation reste entièrement manuelle.

### 4.3. Comparaison détaillée

| Capacité                 | Rapid7 InsightVM      | Cyberwatch                      |
|--------------------------|-----------------------|---------------------------------|
| Déploie des correctifs ? | X Non                 | ✓ Oui (KB, apt/yum/dnf, winget) |
| Windows KB (WSUS)        | Via SCCM uniquement   | ✓ Natif + détection WSUS auto   |
| Logiciels tiers Windows  | X Non documenté       | ✓ Via winget                    |
| Linux (apt/yum/dnf)      | X Non documenté       | ✓ Natif                         |
| WAPT                     | X Aucune intégration  | ✓ API bidirectionnelle          |
| SCCM / BigFix            | ✓ Automation-assisted | X Non documenté                 |
| Planification intégrée   | X Via outil tiers     | ✓ Fenêtres + redémarrage auto   |

| Verdict — Remédiation                                                           |                                                                                                          |
|---------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| <b>Rapid7 InsightVM</b><br>Scanner pur. Pertinent si SCCM/BigFix déjà en place. | <b>Cyberwatch</b><br>Cycle complet détection → déploiement. WAPT bidirectionnel = accélérateur immédiat. |

## 5. Priorisation : trier 12 000 vulnérabilités pour agir sur les bonnes

Sans priorisation efficace, l'équipe SSI se noie. Deux philosophies s'affrontent : scoring propriétaire enrichi (Rapid7) vs. standards ouverts auditables (Cyberwatch).

### 5.1. Rapid7 : écosystème propriétaire d'une richesse inégalée

L'Active Risk Score (1-1000) croise exploitabilité Metasploit, tendances d'attaques (honeypots Lorelei), exposition réseau (Sonar) et contexte métier (RealContext Tags). L'EPSS et le Remediation Hub (supersédence) complètent depuis fin 2025.

**Force** : données exclusives qu'aucun concurrent ne peut reproduire. **Limite** : algorithme opaque, non justifiable devant un auditeur ANSSI.

#### Détail technique — Active Risk Score

L'Active Risk Score est un score composite sur 1 000 qui agrège cinq signaux : (1) le CVSS de base, (2) l'existence d'un exploit dans Metasploit ou exploit-db, (3) les tendances d'exploitation observées sur les honeypots Project Lorelei (Rapid7 opère un réseau mondial de honeypots qui simulent des services vulnérables et enregistrent les tentatives d'exploitation en temps réel), (4) les données de surface d'attaque Project Sonar (si l'actif est exposé sur internet, le score est pondéré à la hausse), et (5) le contexte métier via les RealContext Tags (un serveur de production critique pèse plus qu'un poste de test). Le problème : les pondérations relatives de ces signaux ne sont pas publiées. Un RSSI qui voit un score de 847 ne peut pas décomposer le calcul pour un auditeur.

### 5.2. Cyberwatch : standards ouverts et transparence totale

Le Cyberscore empile CVSS v3.1 + v4.0, SSVC (CISA), EPSS v4, MITRE ATT&CK v17, objectifs DIC, alertes CERT-FR et catalogue CISA KEV. La « priorisation 3D » combine ces signaux en un score entièrement auditable.

**Force** : chaque composante est publique et reproductible. Un RSSI justifie chaque décision devant ANSSI, CNIL ou Cour des comptes. **Limite** : pas de validation active d'exploitabilité, davantage de bruit potentiel.

#### Détail technique — Priorisation 3D Cyberwatch

La priorisation 3D croise trois dimensions indépendantes. Axe 1 — Sévérité intrinsèque : CVSS v4.0 (base + temporal + environnemental). Axe 2 — Probabilité d'exploitation : EPSS v4 (probabilité à 30 jours, calibrée sur les données FIRST) + présence dans le catalogue CISA KEV + alerte CERT-FR ALE en cours. Axe 3 — Impact métier : criticité DIC de l'actif (Disponibilité/Intégrité/Confidentialité, configurable par l'administrateur), mapping MITRE ATT&CK v17 (les CVE mappées à des TTP utilisées par des APT actifs sont survalorisées), et SSVC (catégorisation CISA : Attend/Track/Track\*/Act). Une vulnérabilité qui cumule un CVSS  $\geq 9.0$ , un EPSS  $\geq 0.7$ , une alerte CERT-FR ALE active et un actif classé « critique » en DIC se retrouve automatiquement en tête de la file de remédiation. Chaque composante du score est traçable et auditable.

**Verdict — Priorisation****Rapid7 InsightVM**

Scoring propriétaire puissant (Metasploit, Sonar).  
Algorithme opaque.

**Cyberwatch**

Standards ouverts auditables. CERT-FR natif. Pas de  
validation active.

---

## 6. Grille de synthèse — 24 critères

Ronds pleins (●) = couverture documentée sur 5 points. Ronds vides (○) = non couvert ou non documenté. Flèches = solution dominante sur le critère.

| Critère                 | Rapid7 | Cyberwatch | Dom. |
|-------------------------|--------|------------|------|
| <b>PRÉREQUIS</b>        |        |            |      |
| Serveur                 | ●●○○○  | ●●●●●      | CW ► |
| OS / Docker             | ●●○○○  | ●●●●●      | CW ► |
| Air gap                 | ●○○○○  | ●●●●●      | CW ► |
| <b>DÉCOUVERTE</b>       |        |            |      |
| Hyperviseurs            | ●●●○○  | ●●●●●      | CW ► |
| Cloud                   | ●●●○○  | ●●●●○      | CW ► |
| Conteneurs              | ●○○○○  | ●●●●●      | CW ► |
| Surface externe (Sonar) | ●●●●●  | ○○○○○      | ◀ R7 |
| DNS/CT/WHOIS            | ●○○○○  | ●●●●●      | CW ► |
| Équip. souverains       | ●○○○○  | ●●●●●      | CW ► |
| OT/industriel           | ●●●○○  | ●●●●○      | CW ► |
| <b>SCAN</b>             |        |            |      |
| PAM                     | ●●○○○  | ●●●●●      | CW ► |
| Intune/SSM              | ○○○○○  | ●●●●●      | CW ► |
| Metasploit RCS          | ●●●●●  | ●○○○○      | ◀ R7 |
| Technologies            | ●●●○○  | ●●●●●      | CW ► |
| <b>REMÉDIATION</b>      |        |            |      |
| Patch Windows           | ○○○○○  | ●●●●●      | CW ► |
| Patch Linux             | ○○○○○  | ●●●●●      | CW ► |
| WAPT                    | ○○○○○  | ●●●●●      | CW ► |
| SCCM/BigFix             | ●●●●○  | ○○○○○      | ◀ R7 |
| Politiques              | ○○○○○  | ●●●●●      | CW ► |
| <b>PRIORISATION</b>     |        |            |      |
| Threat Intel            | ●●●●●  | ●●○○○      | ◀ R7 |
| Standards ouverts       | ●●●○○  | ●●●●●      | CW ► |
| ATT&CK                  | ●●●○○  | ●●●●●      | CW ► |
| CERT-FR/CISA KEV        | ●○○○○  | ●●●●●      | CW ► |
| ANSSI natif             | ●○○○○  | ●●●●●      | CW ► |



|       |          |           |
|-------|----------|-----------|
| TOTAL | 49 / 120 | 101 / 120 |
|-------|----------|-----------|

## 7. Sources documentaires

Chaque fait est vérifiable aux adresses ci-dessous (consultées février 2026).

### 7.1. Rapid7 — 17 sources

| Doc                    | Adresse                                                                                                                                                             |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Doc. principale</b> | <a href="https://docs.rapid7.com/insightvm">docs.rapid7.com/insightvm</a>                                                                                           |
| <b>Prérequis</b>       | <a href="https://docs.rapid7.com/insightvm/system-requirements">docs.rapid7.com/insightvm/system-requirements</a>                                                   |
| <b>Dimensionnement</b> | <a href="https://docs.rapid7.com/insightvm/planning-for-capacity-requirements">docs.rapid7.com/insightvm/planning-for-capacity-requirements</a>                     |
| <b>Collectors</b>      | <a href="https://docs.rapid7.com/insightvm/collector-requirements">docs.rapid7.com/insightvm/collector-requirements</a>                                             |
| <b>Discovery</b>       | <a href="https://docs.rapid7.com/insightvm/managing-dynamic-discovery-of-assets">docs.rapid7.com/insightvm/managing-dynamic-discovery-of-assets</a>                 |
| <b>Credentials</b>     | <a href="https://docs.rapid7.com/insightvm/configuring-scan-credentials">docs.rapid7.com/insightvm/configuring-scan-credentials</a>                                 |
| <b>CyberArk</b>        | <a href="https://docs.rapid7.com/insightvm/creating-and-managing-cyberark-credentials">docs.rapid7.com/insightvm/creating-and-managing-cyberark-credentials</a>     |
| <b>Kerberos</b>        | <a href="https://docs.rapid7.com/insightvm/kerberos-credentials-for-authenticated-scans">docs.rapid7.com/insightvm/kerberos-credentials-for-authenticated-scans</a> |
| <b>SCCM</b>            | <a href="https://docs.rapid7.com/insightvm/microsoft-sccm-automation-assisted-patching">docs.rapid7.com/insightvm/microsoft-sccm-automation-assisted-patching</a>   |
| <b>BigFix</b>          | <a href="https://docs.rapid7.com/insightvm/ibm-bigfix-automation-assisted-patching">docs.rapid7.com/insightvm/ibm-bigfix-automation-assisted-patching</a>           |
| <b>Metasploit</b>      | <a href="https://docs.rapid7.com/insightvm/metasploit-remote-check-service">docs.rapid7.com/insightvm/metasploit-remote-check-service</a>                           |
| <b>Sonar</b>           | <a href="https://docs.rapid7.com/insightvm/working-with-project-sonar">docs.rapid7.com/insightvm/working-with-project-sonar</a>                                     |
| <b>Métriques</b>       | <a href="https://docs.rapid7.com/insightvm/vulnerability-metrics-explained">docs.rapid7.com/insightvm/vulnerability-metrics-explained</a>                           |
| <b>Remediation Hub</b> | <a href="https://docs.rapid7.com/insightvm/remediation-hub">docs.rapid7.com/insightvm/remediation-hub</a>                                                           |
| <b>Goals</b>           | <a href="https://docs.rapid7.com/insightvm/goals-and-slacs">docs.rapid7.com/insightvm/goals-and-slacs</a>                                                           |
| <b>RealContext</b>     | <a href="https://docs.rapid7.com/insightvm/applying-realcontext-with-tags">docs.rapid7.com/insightvm/applying-realcontext-with-tags</a>                             |
| <b>Release Notes</b>   | <a href="https://docs.rapid7.com/insight/release-notes-2025-december">docs.rapid7.com/insight/release-notes-2025-december</a>                                       |

### 7.2. Cyberwatch — 21 sources

| Doc                    | Adresse                                                                                                                                                                       |
|------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Doc. principale</b> | <a href="https://docs.cyberwatch.com/help/fr">docs.cyberwatch.com/help/fr</a>                                                                                                 |
| <b>Prérequis</b>       | <a href="https://docs.cyberwatch.com/help/fr/deploy/technical_prerequisites_cyberwatch_setup">docs.cyberwatch.com/help/fr/deploy/technical_prerequisites_cyberwatch_setup</a> |
| <b>Guide</b>           | <a href="https://docs.cyberwatch.com/help/fr/user_guide">docs.cyberwatch.com/help/fr/user_guide</a>                                                                           |
| <b>Découverte</b>      | <a href="https://docs.cyberwatch.com/help/fr/use_assets/discoveries">docs.cyberwatch.com/help/fr/use_assets/discoveries</a>                                                   |
| <b>Agent</b>           | <a href="https://docs.cyberwatch.com/help/fr/use_assets/agent">docs.cyberwatch.com/help/fr/use_assets/agent</a>                                                               |
| <b>Sans agent</b>      | <a href="https://docs.cyberwatch.com/help/fr/use_assets/agentless_connections">docs.cyberwatch.com/help/fr/use_assets/agentless_connections</a>                               |
| <b>Secrets</b>         | <a href="https://docs.cyberwatch.com/.../menu_specific_configuration_tools_secret">docs.cyberwatch.com/.../menu_specific_configuration_tools_secret</a>                       |
| <b>Intune</b>          | <a href="https://docs.cyberwatch.com/.../microsoft_intune_connections">docs.cyberwatch.com/.../microsoft_intune_connections</a>                                               |
| <b>AWS SSM</b>         | <a href="https://docs.cyberwatch.com/.../AWS_SSM_guide">docs.cyberwatch.com/.../AWS_SSM_guide</a>                                                                             |
| <b>Air gap</b>         | <a href="https://docs.cyberwatch.com/help/fr/use_assets/use_airgap">docs.cyberwatch.com/help/fr/use_assets/use_airgap</a>                                                     |
| <b>Air gap PS</b>      | <a href="https://docs.cyberwatch.com/help/fr/APL_documentation/powerShell_airgap">docs.cyberwatch.com/help/fr/APL_documentation/powerShell_airgap</a>                         |

|                        |                                                                                                                                                                           |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Correctifs</b>      | <a href="https://docs.cyberwatch.com/help/fr/use_vulnerability_scanner/deploy_security_fix">docs.cyberwatch.com/help/fr/use_vulnerability_scanner/deploy_security_fix</a> |
| <b>Politiques</b>      | <a href="https://docs.cyberwatch.com/help/fr/configurations/use_deploying_policies">docs.cyberwatch.com/help/fr/configurations/use_deploying_policies</a>                 |
| <b>Logiciels</b>       | <a href="https://docs.cyberwatch.com/help/fr/use_vulnerability_scanner/supported_software">docs.cyberwatch.com/help/fr/use_vulnerability_scanner/supported_software</a>   |
| <b>Systèmes</b>        | <a href="https://docs.cyberwatch.com/help/fr/use_assets/list_supported_systems">docs.cyberwatch.com/help/fr/use_assets/list_supported_systems</a>                         |
| <b>Criticité</b>       | <a href="https://docs.cyberwatch.com/help/fr/configurations/criticality">docs.cyberwatch.com/help/fr/configurations/criticality</a>                                       |
| <b>Scores</b>          | <a href="https://docs.cyberwatch.com/help/fr/encyclopedias/vulnerability_score">docs.cyberwatch.com/help/fr/encyclopedias/vulnerability_score</a>                         |
| <b>Changelog</b>       | <a href="https://docs.cyberwatch.com/.../changelog">docs.cyberwatch.com/.../changelog</a>                                                                                 |
| <b>Fonctionnalités</b> | <a href="https://cyberwatch.fr/vulnerability-manager-fonctionnalites">cyberwatch.fr/vulnerability-manager-fonctionnalites</a>                                             |
| <b>Intégrations</b>    | <a href="https://docs.cyberwatch.com/help/fr/administration/integrations">docs.cyberwatch.com/help/fr/administration/integrations</a>                                     |
| <b>API</b>             | <a href="https://docs.cyberwatch.com/help/fr/API_documentation/API_use">docs.cyberwatch.com/help/fr/API_documentation/API_use</a>                                         |

---